



**UNIVERSITY OF MINES AND TECHNOLOGY
TARKWA, GHANA**

FACULTY OF COMPUTING AND MATHEMATICAL SCIENCES
DEPARTMENT OF CYBERSECURITY AND INFORMATION SYSTEMS

TECHNICAL REPORT

**DESIGNING A ZERO TRUST ARCHITECTURE (ZTA):
PRINCIPLES, FRAMEWORK AND IMPLEMENTATION
STRATEGY**

Prepared in fulfilment of coursework/technical reporting requirements

Submitted by: ENOCH NANA TABI ODURO

Index Number: FCM.41.018.197.23

Lecturer: Dr. Adu Gyamfi

July 2026

ABSTRACT

Traditional network security models rely on a hardened perimeter that implicitly trusts any user, device, or application once inside the corporate network boundary. The proliferation of cloud computing, remote work, mobile devices and third-party integrations has rendered this perimeter-based trust model inadequate, exposing organisations to lateral-movement attacks, credential theft and insider threats. Zero Trust Architecture (ZTA) addresses these weaknesses by adopting the guiding principle of "never trust, always verify", requiring continuous authentication, authorisation and validation of every access request regardless of its origin. This report reviews the fundamental principles of Zero Trust as codified in the National Institute of Standards and Technology (NIST) Special Publication 800-207, examines the core architectural components, identity governance, device posture assessment, micro-segmentation, policy engines and continuous monitoring, and proposes a structured, phased framework for designing and implementing a Zero Trust Architecture within an enterprise environment. The report further discusses deployment models, anticipated benefits, implementation challenges, and concludes with recommendations for organisations seeking to migrate from perimeter-based security to a Zero Trust posture.

Keywords: Zero Trust Architecture, network security, identity and access management, micro-segmentation, least privilege, NIST SP 800-207, cybersecurity.

TABLE OF CONTENTS

ABSTRACT	2
TABLE OF CONTENTS.....	3
LIST OF TABLES	4
1.0 INTRODUCTION.....	5
1.1 Background to the Study	5
1.2 Problem Statement.....	5
1.3 Objectives of the Report	5
1.4 Scope of the Report	6
2.0 LITERATURE REVIEW: CONCEPTUAL FOUNDATIONS OF ZERO TRUST	6
2.1 Evolution from Perimeter Security to Zero Trust	6
2.2 Guiding Tenets of Zero Trust	6
2.3 Related Frameworks	7
3.0 ZERO TRUST ARCHITECTURE: DESIGN FRAMEWORK	7
3.1 Core Architectural Components.....	7
3.2 Deployment Approaches.....	8
3.3 Comparison with Perimeter-Based Security	8
4.0 IMPLEMENTATION STRATEGY AND ROADMAP	9
4.1 Phase 1: Discovery and Asset Inventory	9
4.2 Phase 2: Identity and Access Management Strengthening	9
4.3 Phase 3: Device Posture and Endpoint Security	9
4.4 Phase 4: Network Micro-Segmentation and Policy Enforcement	9
4.5 Phase 5: Continuous Monitoring, Analytics and Automation	9
5.0 BENEFITS AND CHALLENGES OF ZERO TRUST ADOPTION.....	10
5.1 Benefits.....	10
5.2 Challenges.....	10
6.0 CONCLUSION AND RECOMMENDATIONS	10
REFERENCES.....	12

LIST OF TABLES

Table 3.1: Core Components of the NIST SP 800-207 Zero Trust Architecture

Table 3.2: Comparison of Perimeter-Based Security and Zero Trust Architecture

Table 4.1: Phased Implementation Roadmap for Zero Trust Architecture

1.0 INTRODUCTION

1.1 Background to the Study

For over three decades, enterprise network security has been organised around the castle-and-moat paradigm: a well-defended perimeter, firewalls, virtual private networks (VPNs) and demilitarised zones (DMZs), separates a trusted internal network from an untrusted external one. Once a user or device is authenticated at the perimeter, it is generally granted broad, implicit trust to move within the internal network. This model assumes that threats originate primarily from outside the organisation and that internal traffic is inherently safe.

This assumption no longer holds. The widespread adoption of cloud services, Software-as-a-Service (SaaS) applications, bring-your-own-device (BYOD) policies, and distributed or remote workforces has dissolved the traditional network boundary. High-profile breaches attributed to compromised credentials, stolen VPN tokens and lateral movement by attackers who had already breached the perimeter have demonstrated that implicit trust is a critical point of failure. Zero Trust Architecture has emerged as the leading paradigm to address these shortcomings by eliminating implicit trust altogether and requiring explicit verification for every access request, irrespective of network location.

1.2 Problem Statement

Organisations that continue to rely solely on perimeter defences remain vulnerable to credential-based attacks, insider threats and lateral movement once an attacker gains an initial foothold. There is, therefore, a need to review the principles underlying Zero Trust security and to propose a coherent architectural framework that organisations can follow to design and implement a Zero Trust environment in a structured, risk-informed manner.

1.3 Objectives of the Report

The specific objectives of this report are to:

1. Review the fundamental principles and tenets of Zero Trust Architecture as defined in recognised standards.
2. Examine the core architectural components required to implement a Zero Trust environment.
3. Propose a phased framework for designing and deploying Zero Trust Architecture within an enterprise setting.

4. Discuss the anticipated benefits and challenges associated with Zero Trust adoption.

1.4 Scope of the Report

The report focuses on Zero Trust Architecture as applied to enterprise information technology (IT) environments, drawing primarily on the National Institute of Standards and Technology (NIST) Special Publication 800-207 and complementary guidance from the Cybersecurity and Infrastructure Security Agency (CISA) Zero Trust Maturity Model. Operational technology (OT) and industrial control system (ICS) considerations, while acknowledged, are outside the primary scope of this review.

2.0 LITERATURE REVIEW: CONCEPTUAL FOUNDATIONS OF ZERO TRUST

2.1 Evolution from Perimeter Security to Zero Trust

The term "Zero Trust" was popularised by Forrester Research analyst John Kindervag around 2010, who argued that trust itself is a vulnerability and that security architectures should eliminate the notion of a trusted internal network altogether. The concept gained further structure through Google's internal BeyondCorp initiative, which removed VPN-based perimeter access in favour of contextual, per-request authentication for every corporate application. These early efforts culminated in the formalisation of Zero Trust principles by NIST in Special Publication 800-207, which remains the most widely referenced technical standard for Zero Trust Architecture today.

2.2 Guiding Tenets of Zero Trust

NIST SP 800-207 articulates a set of tenets that underpin any Zero Trust design. These tenets are summarised below:

- All data sources and computing services are treated as resources requiring protection, regardless of network location.
- All communication is secured regardless of network location; network location alone does not confer trust.
- Access to individual enterprise resources is granted on a per-session basis, following the principle of least privilege.
- Access is determined by dynamic policy, including the observable state of user identity, device health, and behavioural attributes.

- The enterprise continuously monitors and measures the integrity and security posture of all owned and associated assets.
- Authentication and authorisation are strictly enforced before a session is established and are re-evaluated continuously throughout the session.
- The enterprise collects as much information as possible on the current state of assets, network infrastructure and communications, and uses it to improve its security posture.

2.3 Related Frameworks

Several complementary frameworks reinforce the Zero Trust paradigm. The CISA Zero Trust Maturity Model defines five pillars, identity, devices, networks, applications and workloads, and data, across which organisations assess their maturity from traditional to optimal. The Cloud Security Alliance's Software-Defined Perimeter (SDP) specification provides a technical blueprint for concealing infrastructure from unauthenticated users. Collectively, these frameworks converge on the same underlying philosophy: trust must be continuously earned and verified rather than granted by default.

3.0 ZERO TRUST ARCHITECTURE: DESIGN FRAMEWORK

3.1 Core Architectural Components

A Zero Trust Architecture, as conceptualised by NIST, is built around a logical decision-and-enforcement structure comprising a Policy Engine (PE), a Policy Administrator (PA) and one or more Policy Enforcement Points (PEPs). Table 3.1 summarises the function of each component.

Component	Function
Policy Engine (PE)	Evaluates access requests against enterprise policy and a trust algorithm, using contextual signals such as identity, device posture, and threat intelligence, to render a grant/deny decision.
Policy Administrator (PA)	Establishes or terminates the communication path between a subject and a resource by issuing session-specific credentials or tokens, based on the decision of the Policy Engine.
Policy Enforcement Point (PEP)	Enables, monitors and terminates connections between a subject and an enterprise resource; typically implemented as a gateway, proxy or client-side agent.

Component	Function
Identity and Access Management (IAM)	Provides authoritative identity data, multi-factor authentication (MFA) and single sign-on (SSO) services that feed decisions to the Policy Engine.
Continuous Diagnostics and Mitigation (CDM)	Supplies real-time device and endpoint posture information (patch level, encryption status, malware indicators) used as a policy input.
Security Information and Event Management (SIEM)	Aggregates logs and telemetry across the environment to support continuous monitoring, anomaly detection and audit.

Table 3.1: Core Components of the NIST SP 800-207 Zero Trust Architecture

3.2 Deployment Approaches

NIST identifies several non-mutually-exclusive approaches to realising Zero Trust in practice:

- Enhanced Identity Governance, access decisions are driven primarily by strong identity verification and attribute-based access control (ABAC), with less reliance on network segmentation.
- Micro-Segmentation, the network is divided into small, granular zones (down to individual workloads), each protected by its own gateway that enforces policy before permitting traffic.
- Software-Defined Perimeter (SDP), network infrastructure is rendered invisible to unauthenticated devices; a controller authenticates a subject before dynamically provisioning an encrypted tunnel to the requested resource.

3.3 Comparison with Perimeter-Based Security

Attribute	Perimeter-Based Security	Zero Trust Architecture
Trust model	Implicit trust once inside the network	No implicit trust; continuous verification
Access granularity	Broad, network-level access	Least-privilege, per-session, per-resource access
Lateral movement risk	High, once perimeter is breached	Constrained by micro-segmentation
Remote/cloud suitability	Poor; relies on VPN back-haul	Native support for cloud and remote access
Monitoring	Primarily at the perimeter	Continuous, across all assets and sessions

Table 3.2: Comparison of Perimeter-Based Security and Zero Trust Architecture

4.0 IMPLEMENTATION STRATEGY AND ROADMAP

Designing a Zero Trust Architecture is not a single product deployment but an incremental transformation of people, processes and technology. Drawing on the CISA Zero Trust Maturity Model and NIST guidance, a five-phase roadmap is proposed below.

4.1 Phase 1: Discovery and Asset Inventory

The organisation must first establish a comprehensive inventory of users, devices, applications, data stores and network flows. This baseline is essential because Zero Trust policy cannot protect resources that are unknown or unmanaged. Data classification should also occur at this stage to identify which assets require the highest protection.

4.2 Phase 2: Identity and Access Management Strengthening

Multi-factor authentication, single sign-on and strong identity federation should be deployed enterprise-wide. Identity becomes the new perimeter in a Zero Trust model, and every access decision hinges on high-assurance identity verification.

4.3 Phase 3: Device Posture and Endpoint Security

Endpoint detection and response (EDR) tooling and mobile device management (MDM) solutions are deployed to continuously assess device health, patch status and compliance, feeding this data into the Policy Engine as a precondition for access.

4.4 Phase 4: Network Micro-Segmentation and Policy Enforcement

The flat internal network is progressively segmented into smaller zones, with Policy Enforcement Points placed in front of critical applications and data stores. Software-defined perimeter or secure access service edge (SASE) technologies may be used to broker access dynamically rather than relying on static VPNs.

4.5 Phase 5: Continuous Monitoring, Analytics and Automation

Security orchestration, automation and response (SOAR) platforms, integrated with SIEM, provide continuous analytics on user and entity behaviour, enabling automated revocation of access when anomalous behaviour or a compromised posture is detected.

Phase	Focus Area	Key Activities
1	Discovery & Inventory	Asset inventory, data classification, traffic mapping

Phase	Focus Area	Key Activities
2	Identity Strengthening	MFA, SSO, identity federation, privileged access management
3	Device Posture	EDR, MDM, compliance scoring
4	Micro-Segmentation	PEP deployment, SDP/SASE rollout, least-privilege policy authoring
5	Monitoring & Automation	SIEM/SOAR integration, behavioural analytics, automated response

Table 4.1: Phased Implementation Roadmap for Zero Trust Architecture

5.0 BENEFITS AND CHALLENGES OF ZERO TRUST ADOPTION

5.1 Benefits

- Reduced attack surface and constrained lateral movement through micro-segmentation and least-privilege access.
- Improved visibility into users, devices and data flows across hybrid and multi-cloud environments.
- Stronger regulatory compliance posture through granular, auditable access control.
- Native support for remote and distributed workforces without dependence on traditional VPN infrastructure.

5.2 Challenges

- Legacy applications and infrastructure may not support modern identity protocols, complicating integration.
- Organisational resistance to change and the operational complexity of managing granular policies.
- Significant upfront investment in tooling, skills development and process re-engineering.
- Risk of policy misconfiguration leading to unintended denial of legitimate access or, conversely, overly permissive rules.

6.0 CONCLUSION AND RECOMMENDATIONS

Zero Trust Architecture represents a fundamental shift from implicit, location-based trust to explicit, continuously verified trust grounded in identity, device posture and contextual risk.

This report has reviewed the guiding tenets of Zero Trust as codified in NIST SP 800-207, examined the core architectural components, the Policy Engine, Policy Administrator and Policy Enforcement Points, and proposed a five-phase implementation roadmap spanning asset discovery, identity strengthening, device posture assessment, micro-segmentation and continuous monitoring.

It is recommended that organisations embarking on a Zero Trust journey begin with a thorough asset inventory and identity strengthening programme before attempting network micro-segmentation, as identity and visibility form the foundation upon which all subsequent policy decisions depend. A phased, risk-prioritised approach, rather than a wholesale, all-at-once deployment, is more likely to succeed while minimising disruption to business operations.

REFERENCES

- [1] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, "Zero Trust Architecture," National Institute of Standards and Technology (NIST) Special Publication 800-207, Gaithersburg, MD, USA, Aug. 2020.
- [2] Cybersecurity and Infrastructure Security Agency (CISA), "Zero Trust Maturity Model, Version 2.0," U.S. Department of Homeland Security, Washington, DC, USA, Apr. 2023.
- [3] J. Kindervag, "Build Security Into Your Network's DNA: The Zero Trust Network Architecture," Forrester Research, Cambridge, MA, USA, 2010.
- [4] R. Ward and B. Beyer, "BeyondCorp: A New Approach to Enterprise Security," ;login: The USENIX Magazine, vol. 39, no. 6, pp. 6-11, 2014.
- [5] Cloud Security Alliance, "Software Defined Perimeter (SDP) Specification, Version 2.0," CSA, Seattle, WA, USA, 2022.
- [6] National Cyber Security Centre (NCSC), "Zero Trust Architecture Design Principles," UK Government, London, UK, 2021.
- [7] S. Sarkar, G. Choudhary, S. K. Shandilya, A. Hussain, and H. Kim, "Security of Zero Trust Networks in Cloud Computing: A Comparative Review," Sustainability, vol. 14, no. 18, p. 11213, 2022.
- [8] Microsoft Corporation, "Zero Trust Deployment Guide," Microsoft Security Documentation, Redmond, WA, USA, 2023.